

Verzeichnis von Verarbeitungstätigkeiten (Art. 30 Abs. 1 DSGVO)

Lebensgeschichten-App, Kategorie **Lebenswerk. Vom Verantwortlichen in Kraft gesetzt.** Stand: 2026-08-03. Produktion: lebensgeschichten.ai.

Dieses Dokument erfüllt zusammen mit „Sicherheitskonzept (TOM)“ (technische und organisatorische Maßnahmen, Art. 32) und „Betriebs-Runbook Datenschutz“ (Betriebs-Runbook, Art. 33/34) die Dokumentationspflichten der Rechenschaftspflicht (Art. 5 Abs. 2).

- Begleitende Pflichten (Phase 0 der DSGVO-Roadmap), die NICHT durch dieses Dokument abgedeckt sind:**
- **DSFA (Art. 35)** — erstellt als „Datenschutz-Folgenabschaetzung“.
 - **AVV/DPA herunterladen & archivieren** — siehe Abschnitt 6 (Checkliste).

Zuschnitt auf die valuvita GmbH. Im Auftrag der valuvita GmbH wird ausschließlich die Produktkategorie **Lebenswerk** eingesetzt: Die erzählende Person berichtet ihr eigenes Leben und erhält dafür einen eigenen Zugang. Die Anwendung beherrscht weitere Anlässe — Gedenkbuch, Geburtstag, Jubiläum, Abschied, Geburt, Mutmachbuch, Anamnesebogen —, die hier **nicht beauftragt** und deshalb aus dieser Fassung entfernt sind. Maßgeblich für das Auftragsverhältnis ist diese Fassung.

1. Verantwortlicher & Kontakt (Art. 30 Abs. 1 lit. a)

Feld	Angabe
Verantwortlicher	Lebenswerk.AI GmbH
Sitz	Walter-Schneider-Straße 10, 06317 Seegebiet Mansfelder Land
Vertretung	Geschäftsführer Dr. Gantner
Kontakt Datenschutz	Florian Burg, Projektleiter · florian.burg@lebensgeschichten.ai · support@lebensgeschichten.ai
Datenschutzbeauftragter	Externe Bestellung eingeleitet. Die Benennungspflicht folgt aus § 38 Abs. 1 Satz 2 BDSG (Verarbeitungen, die einer DSFA nach Art. 35 unterliegen) sowie Art. 37 Abs. 1 lit. c. Bis zur Bestellung ist Florian Burg Ansprechpartner für Datenschutzfragen — ausdrücklich nicht als Datenschutzbeauftragter, da er als Projektleiter über Zwecke und Mittel mitentscheidet und damit nach Art. 38 Abs. 6 in einem Interessenkonflikt stünde.
Zuständige Aufsichtsbehörde	Landesbeauftragter für den Datenschutz Sachsen-Anhalt, Magdeburg (Unternehmenssitz Seegebiet Mansfelder Land)

2. Zwecke der Verarbeitung (Art. 30 Abs. 1 lit. b)

Erstellung eines individuellen **Lebenswerks** — eines autobiographischen Buches aus dem, was die erzählende Person selbst berichtet. Es ist die einzige Produktkategorie, die im Auftrag der valuvita GmbH eingesetzt wird.

Das ist eine **Selbsterzählung**: Es gibt keine Gruppe von Beitragenden, die über eine dritte Person berichtet, und der Zugangscode ist der Zugang der erzählenden Person selbst.

Teilzwecke:

1. **KI-gestütztes Interview** (Sprache oder Text) zur Sammlung von Erinnerungen.
2. **Transkription** gesprochener Beiträge (Speech-to-Text).
3. **Sprachausgabe** der KI-Rückfragen (Text-to-Speech).
4. **Synthese** des Buches aus dem Erzählten (LLM); auf Wunsch ebenso Stammbaum, Lebensposter, Pflegeexzerpt, Betreuungsverfügung und Vorsorgevollmacht.
5. **Bilderzeugung** für Buchkapitel (KI).
6. **Inhalts-/Datenschutzprüfung** des erzeugten Textes (LLM).
7. **Kosten- und Zugriffsprotokollierung** (Betrieb, Sicherheit, Abrechnung).
8. **Lizenzverkauf über den Online-Shop** (Vertragsschluss, Zahlung, Rechnung) — getrennte Verarbeitung, siehe Abschnitt 5a. Der Shop kennt **keine** Interview-Inhalte.
9. **Beschäftigtenverwaltung** in dem Umfang, der für die Erbringung der Leistung nötig ist: Konten der eigenen Mitarbeitenden im Dashboard (`app_users`), Protokollierung ihrer Aktionen (`audit_log`).

Keine wissenschaftliche Nutzung. Beiträge und Bücher werden derzeit nicht für Forschung oder Auswertung verwendet. Sollte das vorgesehen werden, holen wir dafür vorab eine **gesonderte, ausdrückliche Einwilligung** der betroffenen Personen ein; ohne sie bleibt es bei der hier beschriebenen Zweckbindung.

3. Kategorien betroffener Personen und personenbezogener Daten (Art. 30 Abs. 1 lit. c)

Betroffenenkategorie	Datenkategorien	Speicherort (Tabelle/Bucket)
Erzählende Person (erzählt ihr eigenes Leben)	Name, Geschlecht, Anrede, Geburtsjahr; Stimmaufnahme ; Interviewinhalt (Freitext); Einwilligungs-Zeitstempel + -Version; die Lebensgeschichte im fertigen Buchtext	<code>contributions</code> , <code>memorials</code> , <code>book_v1/v2</code>
In Beiträgen genannte Dritte	Namen, ggf. Beziehungen/Anschriften lebender Hinterbliebener (im Freitext)	<code>contributions</code> , Buchtext

Betroffenenkategorie	Datenkategorien	Speicherort (Tabelle/Bucket)
Admin-/Kundennutzer	Benutzername, script-Passwort-Hash + Salt , erlaubte Kategorien, Admin-Flag	app_users
Eigene Mitarbeitende (Beschäftigte der Lebenswerk.AI GmbH mit Dashboard-Zugang)	dieselben Kontodaten wie oben; zusätzlich Protokoll ihrer Aktionen (Anmeldung, Anlage/Löschung von Büchern)	app_users , audit_log
Kundinnen und Kunden des Online-Shops	Name, Rechnungs-/Lieferanschrift, E-Mail, Bestell- und Zahlungsdaten	Ecwid (extern), Buchhaltung
Technische Protokolle	IP-Adresse, Zeitstempel, aufgerufener Pfad, Fehlermeldung (Rate-Limiting, Missbrauchsabwehr, Fehlersuche); Aktions-/Login-Ereignisse (PII-arm); Kosten-Events (ohne PII)	rate_limits , audit_log , cost_events

Zugriffsdaten (Logfiles): Rechtsgrundlage ist **Art. 6 Abs. 1 lit. f** (berechtigtes Interesse an sicherem Betrieb), nicht die Einwilligung. Aufbewahrung: `audit_log` 365 Tage, `rate_limits` kurzlebig — beides räumt derselbe Cron auf (Abschnitt 8).

Beschäftigtendaten: Rechtsgrundlage **§ 26 Abs. 1 BDSG** / Art. 6 Abs. 1 lit. b. Die Protokollierung dient der Nachvollziehbarkeit sicherheitsrelevanter Vorgänge, nicht der Leistungs- oder Verhaltenskontrolle.

Besondere Kategorien (Art. 9): StimmAufnahmen sowie Interview-/Buchinhalte können **Gesundheitsdaten, Angaben zu Todesumständen und religiöse Überzeugungen** enthalten. → Rechtsgrundlage Art. 9 Abs. 2 lit. a (ausdrückliche Einwilligung), siehe Abschnitt 4.

4. Rechtsgrundlage & Einwilligung

- **Art. 6 Abs. 1 lit. a** (Einwilligung) und für besondere Kategorien **Art. 9 Abs. 2 lit. a** (ausdrückliche Einwilligung).
- **Protokollierung:** Pflicht-Häkchen vor dem Interview; gespeichert als `consent_at` + Fassungsnummer der Einwilligung am jeweiligen Beitrag. Die jeweils gültige Textfassung steuert `CONSENT_VERSION` (aktuell **1.6**, 2026-08-02).
- **Nicht auf Einwilligung gestützt:** Zugriffsprotokolle (Art. 6 Abs. 1 lit. f), Shop-Bestellungen (lit. b, steuerliche Aufbewahrung lit. c), Beschäftigtenkonten (§ 26 Abs. 1 BDSG).
- **Pflicht zur Bereitstellung:** keine. Ohne Erzählung entsteht kein Buch — das ist der Zweck, nicht eine gesetzliche oder vertragliche Pflicht. Hinweis nach **Art. 13 Abs. 2 lit. e** in der Datenschutzerklärung, Abschnitt 5.
- **Widerruf:** jederzeit per E-Mail an support@lebensgeschichten.ai; das Team löscht Beitrag/Buch manuell. Dokumentiert in der Datenschutzerklärung (Abschnitt 10+11).

- **Datenfluss-Landkarte:** siehe Abschnitt 7.

5. Kategorien von Empfängern / Auftragsverarbeitern (Art. 30 Abs. 1 lit. d)

Stand 2. August 2026, geprüft gegen den Code (sämtliche ausgehenden Verbindungen). Sämtliche Dienste **der Anwendung** verarbeiten **in der EU**; es gibt **keine US-Pfade mehr**. Fällt ein Dienst aus, meldet der Endpunkt einen Fehler, statt auszuweichen. Der Online-Shop steht daneben und ist getrennt geführt (5a).

Auftragsverarbeiter	Leistung	Region / Standort
Microsoft (Azure OpenAI, gpt-4.1 über Foundry)	Interviewführung + Synthese des Buchtextes	EU
Microsoft (Azure AI Speech)	Text-to-Speech + Speech-to-Text	westeurope
Microsoft (Azure AI Speech „Voice Live“)	Live-Sprachgespräch — von der erzählenden Person frei wählbar, nie voreingestellt	swedencentral (einzige EU-Region)
Microsoft (Azure AI Foundry – FLUX.2 [pro])	Bilderzeugung; Modell von Black Forest Labs läuft innerhalb Azure	EU
Microsoft (Azure Database for PostgreSQL Flexible Server)	Datenbank: Bücher, Beiträge, Konten, Kosten, Audit	North Europe
Microsoft (Azure Blob Storage)	Kapitelbilder, hochgeladene Fotos, abgelegte Druck-PDFs	EU
Microsoft (Azure Container Apps + Jobs)	Betrieb der Anwendung und der vier Cron-Jobs	EU
Microsoft (Microsoft 365 / Graph API)	E-Mail-Versand: Zugangs- und Einladungslinks, Wiederaufnahme-Links, Tagesreport, Support-Antworten	M365-Tenant (EU)
Microsoft (GitHub Actions + Azure Container Registry)	Auslieferung neuer Programmstände — keine personenbezogenen Inhalte	—

Ein einziger Anbieter. Nach dem Wegfall des externen QR-Dienstes (siehe unten) verlässt kein personenbezogenes Datum aus der Anwendung den Microsoft-Verbund.

5a. Online-Shop (getrennte Verarbeitung)

Auftragsverarbeiter	Leistung	Region / Standort
Ecwid, Inc. („Ecwid by Lightspeed“), 687 S Coast Hwy 101, Ste. 239, Encinitas, CA 92024, USA; Konzernmutter Lightspeed Commerce Inc., 700 Saint-Antoine St. E., Suite 300, Montréal (Québec) H2Y 1A6, Kanada	Online-Shop für den Lizenzverkauf: Warenkorb, Bestellabwicklung, Bestellhistorie	USA (Drittland, siehe Abschnitt 6)

Datenkategorien im Shop: Name, Rechnungs- und ggf. Lieferanschrift, E-Mail, Bestell- und Zahlungsdaten. **Nicht im Shop:** Interview-Inhalte, Stimmnahmen, Bücher, Fotos — zwischen Shop und Anwendung besteht keine Datenverbindung; Lizenzen werden manuell bzw. über den Buch-Code eingelöst.

Grenze der Verantwortung: Für den Shop ist die Lebenswerk.AI GmbH Verantwortliche. Kundendaten aus dem Shop fließen **nicht** in Verarbeitungen ein, für die wir Auftragsverarbeiterin eines Kunden sind; der Shop taucht deshalb in der Unterauftragnehmer-Anlage des Kunden-AVV bewusst **nicht** auf.

Entfallen (Stand hier zuvor falsch, seit der Azure-Migration am 2026-07-13 ohne Funktion): *Supabase* (Datenbank/Bildspeicher) und *Vercel* (Hosting) sind aus der Produktion entfernt; im Repository verbliebene Artefakte sind Rollback-Referenzen.

Ebenfalls entfallen: `api.qrserver.com` erzeugte bis zum 1. August 2026 die QR-Codes im Dashboard. Dabei ging die vollständige Einladungs-URL **samt Buch-Code** an einen Dritten — beim Lebenswerk ist dieser Code die gesamte Berechtigung des Endnutzers. QR-Codes entstehen seither im Browser (`qrCodeDataUrl` in); der Dienst ist aus dem Code entfernt.

Black Forest Labs (FLUX) ist Modellanbieter, **erhält die Daten aber nicht** — die Verarbeitung findet in Microsoft Azure statt. Kein eigener Datenfluss zu BFL.

6. Übermittlung in Drittländer (Art. 30 Abs. 1 lit. e) + AVV-Checkliste

Anwendung (Interview, Buch, Bilder, Speicherung): keine Drittlandübermittlung. Sämtliche Verarbeitung und Speicherung erfolgen in der EU/EWR.

Einzige Ausnahme: der Online-Shop. Ecwid, Inc. verarbeitet die Bestelldaten in den **USA**. Gestützt auf:

Grundlage	Angabe
Art. 45 DSGVO	Ecwid, Inc. ist unter dem EU-US Data Privacy Framework zertifiziert (Liste des US-Handelsministeriums; Angemessenheitsbeschluss der Kommission vom 10.07.2023)
Art. 46 Abs. 2 lit. c	zusätzlich Standardvertragsklauseln im Auftragsverarbeitungsvertrag mit Lightspeed/Ecwid
Betroffene Daten	ausschließlich Bestelldaten (Abschnitt 5a) — keine Interview-Inhalte, keine besonderen Kategorien nach Art. 9
Hinweis an Betroffene	Datenschutzerklärung, Abschnitt 8

Eingehende AVVs (wir als Verantwortlicher gegenüber unseren Dienstleistern)

Anbieter	Dokument	Status
Microsoft (Azure, Microsoft 365, GitHub)	„Microsoft Products and Services Data Protection Addendum (DPA)“	✅ Fassung Mai 2026 (DE), abgelegt 2026-06-22 in DSGVO_AVV/ . Deckt Azure-Dienste, M365/Graph und GitHub ab.
Ecwid / Lightspeed (Online-Shop)	„Data Processing Agreement“ samt Standardvertragsklauseln	✅ abgeschlossen, abgelegt in DSGVO_AVV/
Black Forest Labs	kein eigener AVV nötig, solange die Verarbeitung in Azure bleibt	n/a
~~Supabase~~,~~Vercel~~	DPAs 2026-06-22 archiviert	historisch — Dienste nicht mehr im Einsatz

Ausgehender AVV (wir als Auftragsverarbeiter gegenüber unseren Kunden)

Betreut ein Kunde — etwa ein Bestattungshaus, eine Klinik oder ein Unternehmen — eigene Endkunden über die Plattform, ist **er** der Verantwortliche und die Lebenswerk.AI GmbH **Auftragsverarbeiterin** nach Art. 28 DSGVO. Der zugehörige Vertragsentwurf samt TOM- und Unterauftragnehmer-Anlage liegt in „**Auftragsverarbeitungsvertrag**“ und ist vor dem ersten produktiven Kundeneinsatz zu unterzeichnen.

7. Datenfluss-Landkarte

`` Erzählende Person (Browser) | lebensgeschichten.ai/?code=XXXXXXXXXX (+ optional &session=YYY) ▼ [Azure Container Apps - Express (server.js) + /api/*, EU] | Sprache rein → /api/transcribe → Azure AI Speech (westeurope) → Text | Frage/Antwort → /api/ask → Azure OpenAI gpt-4.1 (EU) → Text | Vorlesen → /api/speak → Azure AI Speech (westeurope) → Audio | Live-Gespräch → /api/voicelive-relay → Azure Voice Live (Schweden) → Audio | (nur wenn am Buch freigeschaltet; Default aus) | Beitrag/Buch → Azure Database for PostgreSQL (North Europe) | Bilder/Uploads → Azure Blob Storage (EU, privat, SAS-signierte Lesezugriffe) | Buch/Bilder (Manager) → /api/ask + /api/admin/generate-image | → Azure Foundry FLUX (EU) → Blob Storage | E-Mail → Microsoft Graph (M365) → Zugangslink, Wiederaufnahme, Tagesreport, Support Aufbewahrung: Container-Apps-Job (täglich 03:00) → Löschung nach Frist (DB + Blob) ``

Kein Pfeil verlässt die EU. Sekundärdaten (IP-Rate-Limits, Audit, Kostenerfassung) liegen in derselben Datenbank (EU). QR-Codes und Buch-PDFs entstehen im Browser der Nutzerin bzw. des Nutzers, ohne weitere Empfänger.

8. Aufbewahrung / Löschfristen (Art. 30 Abs. 1 lit. f)

- **Beiträge (PII):** automatische Löschung **90 Tage nach Ende der Nutzungsdauer** (RETENTION_DAYS , Standard 90) via der Anwendung (Container-Apps-Job, täglich 03:00). Die Nutzungsdauer endet mit funeral_date ; ist kein Anlassdatum hinterlegt, created_at + LICENSE_MONTHS (Standard **6 Monate**,

die vertragliche Lizenzlaufzeit). Erhalten bleibt dann nur noch das fertige Buch (ohne Interview-Rohdaten); pro Beitrag wird ein Tombstone in `memorials.purge_info` vermerkt.

> **Warum nicht schlicht „Anlage + 90 Tage“ (Stand bis 2026-08-02):** Die Lizenz > läuft sechs Monate. Eine Löschung nach 90 Tagen hätte mitten in der bezahlten > Laufzeit die Eingangsdaten entfernt — der Kunde hätte noch Anspruch gehabt, aber > nichts mehr, woraus ein Buch entstehen könnte. Gegenüber Art. 5 Abs. 1 lit. e > gerechtfertigt: Solange erzählt werden darf, sind die Beiträge für den Zweck > erforderlich. Bücher mit Anlassdatum sind unverändert (Anlass + 90 Tage).

- `audit_log` (Zugriffs-/Aktionsprotokoll inkl. IP): 365 Tage, danach automatisch gelöscht (Housekeeping im selben Cron).
- `rate_limits` : kurzlebig, Ablauf am selben Tag (Housekeeping).
- **Shop-Bestelldaten:** solange für die Vertragsabwicklung nötig; Rechnungen und Buchungsbelege **10 Jahre** (§ 147 AO, § 257 HGB).
- **Konten von Mitarbeitenden und Kundennutzern:** bis zum Entzug des Zugangs, danach Löschung des Kontos; das Aktionsprotokoll läuft nach 365 Tagen aus.
- **Manuelle Voll-Löschung** (Admin) entfernt Buch, Beiträge, Kosten-Events und Storage-Bilder vollständig.
- **Betroffenenrechte:** Auskunft/Export (Art. 15/20) als ZIP (PDF + JSON) pro Beitrag im Admin; Löschung (Art. 17) vollständig inkl. Storage.

9. Allgemeine Beschreibung der TOMs (Art. 30 Abs. 1 lit. g)

Vollständig in „**Sicherheitskonzept (TOM)**“. Kurzfassung: TLS in transit + AES-256 at rest; Datenbank NUR aus dem Backend erreichbar (eigener DB-Benutzer, kein öffentlicher Endpunkt); HMAC-signierte Admin-Tokens mit 12 h TTL, keine Default-Credentials; Mehrbenutzer- Isolation (IDOR-geschützt); Rate-Limiting + Brute-Force-Schutz; Passwortrichtlinie; dauerhaftes Audit-Logging; Secrets nur serverseitig.